SUNFZENITH TECHNICAL SPECIFICATION

SUNFZENITH (ซันเอฟซีนิท)

Small Dream, Big Zenith — คู่มือสถาปัตยกรรมระบบและโครงสร้างโค้ดฉบับสมบูรณ์

เอกสารฉบับนี้จัดทำขึ้นเพื่ออธิบายหลักการทำงานของเว็บไซต์ SUNFZENITH อย่างละเอียด เจาะลึกโครงสร้างโค้ดทุกโฟลเดอร์ ทุกไฟล์ ระบบรักษาความปลอดภัย การเชื่อมต่อฐานข้อมูล ตลอดจนการทำงานทั้งส่วนหน้าบ้าน (Frontend) และส่วนหลังบ้าน (Backend & Admin Studio)

เวอร์ชันระบบ **2.0.0 (Production Ready)**	สถาปัตยกรรมหลัก **Full-Stack Hybrid Resilience**
เซิร์ฟเวอร์ & ฐานข้อมูล **Node.js, Express v5, Supabase (PostgreSQL)**	เครื่องมือหน้าบ้าน **Vite 8, Tailwind CSS, Modular Vanilla JS**
สถานะการทดสอบ **ผ่าน 61 / 61 Tests (100% Passed)**	ผู้พัฒนาและเจ้าของลิขสิทธิ์ **SUNFZENITH Digital Studio**

1. ภาพรวมของระบบและจุดประสงค์หลัก (System Overview)

เว็บไซต์ **SUNFZENITH** เป็นเว็บแอปพลิเคชันรูปแบบ Full-Stack ที่รวบรวมฟังก์ชันการทำงาน 3 มิติหลักไว้ในแพลตฟอร์มเดียวกันอย่างกลมกลืน:

- **1. Brand Website & Portfolio (หน้าร้านและพอร์ตโฟลิโอ - `/`):** ทำหน้าที่เป็น Landing Page นำเสนอบริการดิจิทัล (รับทำเว็บไซต์, Web App, ออกแบบสไลด์, โปสเตอร์/อินโฟกราฟิก), แสดงตัวอย่างผลงานที่คัดกรองตามหมวดหมู่ได้, มีหน้าต่าง Lightbox ขยายดูภาพชัดเจน, และมี Rate Card Modal สำหรับดูตารางเรทราคาทุกระดับอย่างโปร่งใส
- **2. Credits & Reviews Platform (สมุดรวมเครดิตและรีวิวลูกค้า - `/credits`):** ทำหน้าที่สร้างความน่าเชื่อถือระดับสูงสุด โดยบันทึกประวัติการส่งมอบงานจริง 100% เชื่อมต่อระบบรีวิวแบบเปิดที่ลูกค้าสามารถกด **+1 (ให้เครดิต)** หรือ **-1 (รายงานปัญหา)** พร้อม *"ระบบบังคับแนบรูปภาพหลักฐานสลิป/แชท"* เพื่อป้องกันสแปม มีระบบค้นหา Real-Time Debounce และระบบ Deep-Link เปิดดูเครดิตใบเฉพาะผ่าน URL ได้ทันที
- **3. Admin Studio (ห้องควบคุมหลังบ้าน - `/admin`):** ศูนย์กลางบริหารจัดการเนื้อหา (Full CMS) ของเจ้าของร้าน เข้าสู่ระบบด้วยรหัส PIN ปลอดภัยสูง จัดการได้ทั้งเนื้อหาหน้าแรก, หัวข้อบริการ, แพ็กเกจราคา, รายการผลงาน, เครดิตร้าน, ลบรีวิวที่ไม่เหมาะสม, เปลี่ยน PIN, ตลอดจนการ **Export / Import Backup JSON** เพื่อสำรองและกู้คืนข้อมูลทั้งระบบ

> 💡 **จุดเด่นเรื่องความทนทาน (Hybrid Data Resilience):**
> ระบบถูกออกแบบมาให้ไม่มีวันล่ม หากเซิร์ฟเวอร์สามารถเชื่อมต่อกับ Supabase Cloud ได้ ข้อมูลจะถูกจัดเก็บบน PostgreSQL และ Cloud Storage แต่หากไม่มีเน็ตหรือเชื่อมต่อไม่ได้ เซิร์ฟเวอร์จะสลับไปอ่าน-เขียนไฟล์ JSON และโฟลเดอร์ไฟล์ในเครื่องแบบอัตโนมัติ 100%

2. เทคโนโลยีและเครื่องมือที่ใช้ (Tech Stack & Tooling)

ส่วนงาน (Layer)	เทคโนโลยี / ไลบรารี	บทบาทหน้าที่และความสำคัญ
Backend Runtime	`Node.js (v20+)` (ES Modules)	รันระบบเซิร์ฟเวอร์ด้วยมาตรฐาน JavaScript สมัยใหม่ รองรับ `import / export`
Web Framework	`Express v5 (^5.2.1)`	จัดการ HTTP Request, Routing, Middlewares และระบบ Error Handling ที่แม่นยำ
Database & Storage	`Supabase (@supabase/supabase-js)`	ฐานข้อมูล PostgreSQL บนคลาวด์ พร้อม Storage Bucket `credit-images` เก็บรูปภาพ
File Upload Engine	`Multer (^2.4.0)` (Memory Storage)	รับไฟล์รูปภาพเข้า Buffer ในหน่วยความจำเพื่อตรวจสอบไบต์ก่อนบันทึกจริง ป้องกันไฟล์แฝง
Cryptography & Auth	`node:crypto (Built-in)`	เข้ารหัส Scrypt พร้อม Salt สำหรับ PIN, สร้างโทเคนเซสชัน HMAC-SHA256, และ Timing-Safe check
Frontend Bundler	`Vite (^8.3.3)`	คอมไพล์และแพ็กรวมหน้าเว็บ (Bundling), ย่อขนาดโค้ด, และจำลอง Dev Server Proxy
Styling & Design	`Tailwind CSS + CSS Design Tokens`	จัดสไตล์หน้าเครดิตและแอดมินด้วย Tailwind ร่วมกับ Custom Design Tokens หน้าแรกเพื่อสลับธีมมืด/สว่าง
Automated Testing	`Vitest (^5.0.3) + Supertest (^7.3.1)`	รันชุดทดสอบ Integration & Unit Tests ตรวจจับบั๊กและข้อผิดพลาดอัตโนมัติ 61 รายการ

3. โครงสร้างโฟลเดอร์และไฟล์ทุกส่วนอย่างละเอียด (File & Directory Breakdown)

ด้านล่างนี้คือแผนผังไฟล์ทั้งหมดในระบบ พร้อมคำอธิบายหน้าที่แบบ 1-ต่อ-1:

โฟลเดอร์ / ชื่อไฟล์	หน้าที่และคำอธิบายการทำงาน
`server.js`	**Entry Point ของเซิร์ฟเวอร์:** ดึงการตั้งค่าจาก `config.js` เรียก `createApp()` ทำการ Health Check เชื่อมต่อ Supabase แล้วสั่งเปิดพอร์ตรับคำขอ (Default Port 3000)
`src/server/app.js`	**ศูนย์รวมการตั้งค่า Express:** รวบรวม Middlewares ด้านความปลอดภัย (CSP, CORS, Compression, Rate Limit), จัดการเส้นทาง Static Files (เสิร์ฟจาก `dist/` ในโหมด Production), เส้นทาง API, และดักจับหน้า 404 / 500
`src/server/config.js`	**ศูนย์รวมการอ่านค่า Environment:** ตรวจสอบตัวแปรระบบอย่างเข้มงวด หากรันใน Production จะบังคับว่าต้องมี `SESSION_SECRET` ยาวไม่ต่ำกว่า 32 ตัวอักษร และต้องใช้ `SUPABASE_SERVICE_ROLE_KEY` เท่านั้น
`src/server/routes/public.js`	**API ฝั่งสาธารณะ:** ให้บริการ `GET /content`, `GET /settings`, `GET /credits`, `GET /portfolio`, `GET /reviews` และ `POST /reviews` (ส่งรีวิวพร้อมอัปโหลดรูปภาพ)
`src/server/routes/admin.js`	**API ฝั่งแอดมิน:** ล็อกอิน `/login`, ตรวจสอบเซสชัน `/check`, CRUD บริการ, แพ็กเกจราคา, ผลงาน, เครดิตร้าน, ลบรีวิว, เปลี่ยน PIN, ตลอดจนระบบ `/export` และ `/import` Backup JSON
`src/server/routes/seo.js`	**จัดการ Search Engine:** สร้างไฟล์ `/robots.txt` และ `/sitemap.xml` อัตโนมัติ เพื่อให้ Google ค้นหาหน้าเว็บเจอและจัดอันดับได้ดีขึ้น
`src/server/services/db.js`	**หัวใจหลักในการติดต่อฐานข้อมูล:** ควบคุมการอ่านเขียนข้อมูลเครดิต, รีวิว, การตั้งค่าร้าน, การอัปโหลดรูปภาพไปยัง Supabase Storage พร้อมฟังก์ชัน Fallback ไปยัง Local JSON อัตโนมัติ
`src/server/services/contentDb.js`	**ระบบจัดการ CMS:** ควบคุมข้อมูลข้อความหน้าแรก, รายการบริการ (Services CRUD) และแพ็กเกจราคา (Pricing CRUD) เก็บใน `content.json`
`src/server/services/portfolioDb.js`	**ระบบจัดการผลงาน:** ควบคุมรายการผลงาน Showcase, ป้ายหมวดหมู่, ลิงก์ดูตัวอย่าง, แท็กเทคโนโลยี เก็บใน `portfolio.json`
`src/server/middleware/security.js`	**ระบบรักษาความปลอดภัย:** บรรจุฟังก์ชัน `hashPin()` (Scrypt), `verifyPin()`, สร้างและตรวจสอบ Session Cookie (HMAC-SHA256), ตรวจสอบ `sameOriginGuard()` ป้องกัน CSRF และกำหนด Security Headers
`src/server/middleware/rateLimit.js`	**ระบบป้องกันสแปม:** ใช้อัลกอริทึม Sliding Window ใน Memory คอยตรวจจับ IP จำกัดการพยายามล็อกอินไม่เกิน 5 ครั้ง/15 นาที และส่งรีวิวไม่เกิน 5 ครั้ง/10 นาที
`src/server/middleware/upload.js`	**ระบบอัปโหลดไฟล์:** ตั้งค่า Multer Memory Storage จำกัดขนาด 5MB ต่อรูป สูงสุด 5 รูป พร้อมฟังก์ชัน `detectImageMime()` สแกน Magic Bytes ตรวจจับว่าเป็นไฟล์ภาพ JPG/PNG/WebP แท้จริง

โฟลเดอร์ / ชื่อไฟล์	หน้าที่และคำอธิบายการทำงาน
`src/shared/validation.js`	**โมดูลตรวจสอบข้อมูลร่วม (Isomorphic):** ฟังก์ชันกรองข้อความ (Sanitize URL, Escape HTML) และตรวจสอบความถูกต้องของฟอร์มที่ใช้ร่วมกันได้ทั้งบนเบราว์เซอร์และบนเซิร์ฟเวอร์
`web/index.html`	**โครงสร้างหน้าแรก:** หน้าร้านโชว์ผลงาน, แนะนำบริการ, ตารางราคา, ขั้นตอนการทำงาน, Rate Card Modal, และกล่องติดต่อ LINE OA
`web/credits.html`	**โครงสร้างหน้าเครดิต:** หน้ารวมฟีดเครดิตการขาย, ปุ่มสลับแท็บทั้งหมด/+1/-1, ช่องค้นหา, ฟอร์มส่งรีวิวลูกค้า, และ Lightbox ขยายดูภาพสลิป
`web/public/admin.html`	**โครงสร้างหน้าแอดมิน:** หน้าต่างกรอก PIN สำหรับเข้าสู่ระบบ และแผงแดชบอร์ด 9 แท็บสำหรับบริหารจัดการทั้งระบบ
`web/src/entries/home.js`	**สคริปต์ควบคุมหน้าแรก:** สลับธีมมืด/สว่าง, เลื่อนเปิดเมนูมือถือ, กรองผลงานตามแท็บ, ดึงข้อมูล CMS จากเซิร์ฟเวอร์, เปิดปิด Rate Card Modal และ Portfolio Lightbox
`web/public/js/app.js`	**สคริปต์ควบคุมหน้าเครดิต:** ดึงรายการเครดิตและรีวิว, รองรับการค้นหา, ส่งรีวิวพร้อมรูปภาพ, เปิดดูรูปขยายใหญ่, ซูมภาพ, และคัดลอกลิงก์ Deep-link
`web/public/js/admin.js`	**สคริปต์ควบคุมหน้าแอดมิน:** ควบคุมตรรกะการล็อกอิน, การสลับแท็บควบคุม, การบันทึกข้อมูลฟอร์ม, อัปโหลดภาพ, ตลอดจนการดาวน์โหลดและอัปโหลดไฟล์สำรองข้อมูล JSON
`scripts/postinstall.js`	**สคริปต์อัตโนมัติหลังติดตั้ง:** สั่งรัน `vite build` สร้างโฟลเดอร์ `dist/` อัตโนมัติทันทีที่ Deploy ขึ้นแพลตฟอร์ม Cloud เช่น Render

4. เจาะลึกการทำงานของหน้าเว็บหลักทั้ง 3 หน้า (Deep Dive Pages)

🌐 1. Brand Studio & Showcase (หน้าแรก /)

- **Zero-Flicker Theme:** มีสคริปต์ดักจับใน <head> อ่านธีมจาก localStorage ก่อนเบราว์เซอร์วาดหน้าจอ หมดปัญหาหน้าจอขาววาบเมื่อเปิด Dark Mode
- **Dynamic CMS Sync:** ข้อความหัวเว็บ, สโลแกน มาสคอต, แถบประกาศ (Announcement), และลิงก์โซเชียลจะดึงจาก Backend แบบ Real-time แก้ไขในแอดมินแล้วหน้าเว็บเปลี่ยนทันที
- **Portfolio Filter & Lightbox:** แสดงผลงานจัดหมวดหมู่ คลิกดูภาพขยายใหญ่พร้อมคำอธิบายและแท็กเทคโนโลยี
- **Rate Card Modal:** ป๊อปอัปตารางราคาละเอียด แบ่ง 5 แท็บ: ทำเว็บ, สไลด์, โปสเตอร์, เช็กลิสต์, และเงื่อนไขการทำงาน
- **LINE OA CTA:** ปุ่มติดต่อมุ่งตรงไปยัง LINE OA `@419ajynp`

👍 2. Credits & Reviews Platform (หน้ `/credits`)

- **3-Mode Feed Tabs:** สลับดูได้ระหว่าง "เครดิตทั้งหมดจากร้าน", "👍 +1 รีวิวจากลูกค้า", และ "⚠️ -1 รายงานปัญหา"
- **Real-Time Search:** ช่องค้นหาพร้อมระบบ Debounce 300ms ค้นหาทั้งชื่อสินค้า, ลูกค้า, และข้อความรีวิว
- **Mandatory Proof Review:** ลูกค้าสามารถส่งรีวิวได้ แต่บังคับต้องแนบรูปหลักฐานสลิป/แชท (สูงสุด 5 รูป) เพื่อป้องกันสแปม
- **Deep-Link URL:** คลิกดูเครดิตใบใด URL จะเปลี่ยนเป็น `?credit=<id>` สามารถก็อปลิงก์ไปแชร์ให้ผู้อื่นเปิดดูภาพขยายของเครดิตใบนั้นได้ทันที
- **Zoom & Slider:** ซูมภาพได้ 1.6x และสลับดูรูปภาพย่อยได้อย่างลื่นไหล

🔑 3. Admin Studio (ห้องควบคุมหลังบ้าน `/admin`)

ระบบจัดการหลังบ้านที่เข้าถึงได้ด้วยรหัส PIN โดยระบบจะออก Session Cookie แบบ **HttpOnly; SameSite=Lax** (อายุ 7 วัน) ภายในแบ่งออกเป็น 9 แท็บครอบคลุมทุกมิติ:

- 🏠 **หน้าแรก:** แก้ข้อความ Hero, คำประกาศ, สถานะเปิดร้าน
- 🌐 **บริการ:** เพิ่ม/แก้ไข/ลบหัวข้อบริการและราคาเริ่มต้น
- 🏷️ **แพ็กเกจราคา:** ปรับแต่งการ์ดราคาและรายการฟีเจอร์เด่น
- 🎨 **ผลงาน:** เพิ่มผลงานใหม่ อัปโหลดรูป ระบุหมวดหมู่และลิงก์
- 💬 **โซเชียล:** อัปเดตลิงก์ LINE OA, Facebook, Discord, TikTok
- ➕ **เพิ่มเครดิต:** บันทึกประวัติการขาย แนบรูปภาพสลิป ระบุราคา
- 📋 **จัดการเครดิต:** แก้ไข ลบ หรือกด "ปักหมุด" นำรายการขึ้นบนสุด
- ⭐ **จัดการรีวิว:** ตรวจสอบและลบรีวิวที่เข้าข่ายสแปมหรือผิดระเบียบ
- ⚙️ **ตั้งค่า & สำรอง:** เปลี่ยนรหัส PIN และกด **Export / Import Backup JSON** เพื่อสำรองหรือกู้คืนข้อมูลได้ในคลิกเดียว

5. ระบบความปลอดภัยและการตรวจสอบข้อมูล (Security Architecture)

ระบบ SUNFZENITH ถูกสร้างขึ้นด้วยมาตรฐานความปลอดภัยระดับ Production ครอบคลุม 6 ชั้น:

ด่านความปลอดภัย	เทคโนโลยีที่ใช้	ผลลัพธ์ในการป้องกัน
1. รหัสผ่านแอดมิน	`Scrypt Hashing + Random Salt`	รหัส PIN จะถูกเติม Salt สุ่ม 16 ไบต์ และเข้ารหัสด้วย Scrypt ทนทานต่อการโจมตีแบบ Brute-Force และ GPU Cracking
2. เซสชันแอดมิน	`HMAC-SHA256 Signed Cookie`	โทเคนถูกส่งผ่านคุกกี้ `HttpOnly; SameSite=Lax; Secure` ป้องกันการถูกขโมยผ่านสคริปต์หน้าบ้าน (XSS Protection)
3. ป้องกันการสุ่มเวลา	`crypto.timingSafeEqual`	เปรียบเทียบสตริงรหัสผ่านและโทเคนด้วยเวลาคงที่ ป้องกันการเจาะระบบด้วยวิธี Timing Attack
4. ป้องกันข้ามไซต์ (CSRF)	`sameOriginGuard Middleware`	ตรวจสอบ Origin Header ในคำขอ POST/PUT/DELETE ให้ตรงกับโดเมนของเซิร์ฟเวอร์เท่านั้น บล็อกคำขอข้ามโดเมนทันที
5. สแกนไฟล์อัปโหลด	`Magic Bytes Inspection`	ตรวจไบต์แท้จริงของไฟล์รูปภาพใน Buffer (FF D8 FF สำหรับ JPG, 89 50 4E 47 สำหรับ PNG) ปฏิเสธไฟล์ SVG/HTML/Script ป้องกันการฝังโค้ดอันตราย
6. ป้องกันการยิงสแปม	`Sliding Window Rate Limiter`	จำกัดความถี่คำขอต่อ IP: ล็อกอินได้ไม่เกิน 5 ครั้ง/15 นาที, ส่งรีวิวไม่เกิน 5 ครั้ง/10 นาที, คำขอทั่วไปไม่เกิน 120 ครั้ง/นาที

6. ลำดับขั้นตอนการทำงานของข้อมูล (End-to-End Data Flows)

Flow ตัวอย่าง: การส่งรีวิว +1 หรือ -1 ของลูกค้า

1. ลูกค้ากดปุ่ม "ให้คะแนนร้าน +1" หรือ "รายงานปัญหา -1" ในหน้า `/credits`
2. ฟอร์มแสดงขึ้นมา ลูกค้ากรอกชื่อ, ข้อความรีวิว, และ **เลือกรูปภาพหลักฐาน** (สลิปหรือภาพแชท)
3. JavaScript ฝั่งเบราว์เซอร์ตรวจสอบชนิดไฟล์เบื้องต้นและขนาดไม่เกิน 5MB ต่อไฟล์
4. คำขอถูกส่งแบบ `multipart/form-data` ไปที่ `POST /api/public/reviews`
5. เซิร์ฟเวอร์ตรวจสอบความถี่คำขอ (Rate Limiting) และนำไฟล์เข้า Memory Buffer ผ่าน Multer
6. ฟังก์ชัน `detectImageMime()` สแกน Magic Bytes ตรวจสอบว่าเป็นไฟล์ภาพแท้จริง
7. เซิร์ฟเวอร์อัปโหลดรูปภาพไปยัง Supabase Storage Bucket `credit-images`
8. เซิร์ฟเวอร์บันทึกข้อมูลรีวิวลงตาราง `customer_reviews` ใน Supabase PostgreSQL
9. *(กรณีผิดพลาด):* หากฐานข้อมูลบันทึกไม่สำเร็จ ระบบจะทำการ **Rollback ลบรูปภาพที่เพิ่งอัปโหลดทิ้งทันที** ไม่ทิ้งขยะตกค้าง
10. เซิร์ฟเวอร์ตอบกลับ `{ success: true }` -> หน้าเว็บอัปเดตตัวเลขสถิติและแสดงรีวิวใหม่ทันที

7. คู่มือคำสั่งและการนำขึ้นใช้งาน (Commands & Runbook)

คำสั่งสำหรับนักพัฒนาในการทดสอบ รัน และจัดการระบบ:

คำสั่ง (Command)	การทำงานและผลลัพธ์
`npm run dev`	รันเซิร์ฟเวอร์ฝั่ง Frontend ด้วย Vite สำหรับการเขียนและดูผลแบบ Hot Module Replacement (HMR)
`npm run dev:server`	รัน Backend Express เซิร์ฟเวอร์ด้วยโหมด Node Watch (รีสตาร์ตอัตโนมัติเมื่อแก้โค้ดเซิร์ฟเวอร์)
`npm run build`	คอมไพล์และสร้าง Production Bundle เก็บไว้ที่โฟลเดอร์ `dist/` พร้อมใช้งานจริง
`npm start`	รันเซิร์ฟเวอร์ Production จริง (เสิร์ฟทั้ง API และหน้าเว็บจากโฟลเดอร์ `dist/`)
`npm test`	รันชุดทดสอบอัตโนมัติทั้งหมด 61 การทดสอบด้วย Vitest เพื่อตรวจเช็กความสมบูรณ์ของระบบ
`npm run qa`	รันสคริปต์ตรวจความสมบูรณ์ของ Production Build (ตรวจไฟล์ HTML, CSS, WOFF2 ฟอนต์ และการตั้งค่า)

ตัวแปรสภาพแวดล้อมที่สำคัญ (Environment Variables)

- `PORT`: พอร์ตที่ต้องการเปิดบริการ (ค่าเริ่มต้นคือ `3000`)
- `NODE_ENV`: ตั้งค่าเป็น `production` เพื่อเปิดโหมดความปลอดภัยสูงสุด
- `SESSION_SECRET`: รหัสลับสุ่มอย่างน้อย 32 ตัวอักษรสำหรับเซ็นรับรองคุกกี้เซสชันของแอดมิน
- `ADMIN_PIN`: รหัสผ่าน PIN สำหรับแอดมิน (ความยาว 6-64 ตัวอักษร ห้ามใช้รหัสคาดเดาง่าย เช่น 1234 หรือ 3645)
- `SUPABASE_URL`: URL โปรเจกต์ Supabase ของคุณ (เช่น `https://xxxx.supabase.co`)
- `SUPABASE_SERVICE_ROLE_KEY`: กุญแจ Service Role Key สำหรับสิทธิ์จัดการฐานข้อมูลและ Storage ฝั่งเซิร์ฟเวอร์
- `SITE_URL`: โดเมนหลักของเว็บไซต์ (เช่น `https://sunfz-credits.onrender.com`)

> ✨ **สรุปภาพรวม:**
> ระบบของ SUNFZENITH ได้รับการออกแบบโครงสร้างตามหลัก Clean Architecture, มีความปลอดภัยระดับสูง (Zero Trust), มีความยืดหยุ่นด้วยระบบคู่ขนาน (Supabase + Local Fallback), และมีประสิทธิภาพการโหลดหน้าเว็บที่รวดเร็ว พร้อมรองรับการเติบโตของธุรกิจได้อย่างมั่นคง 🌞 ✨